

Table of Contents

Cisco Secure Workload — MITRE ATT&CK (Enterprise) Mapping

Reference Design | Threat Detection & Containment Evidence

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

ATT&CK Reference: MITRE ATT&CK for Enterprise (matrices, tactics, techniques)

Reader's Guide

Who this is for. Security operations, detection engineering, and purple teams building coverage narratives against the MITRE ATT&CK Enterprise matrix; architects proving workload-tier detection and containment for assessments, tabletop exercises, or customer security reviews.

Questions this reference design helps you answer:

- *For each top-level tactic (Initial Access through Impact), what does CSW observe or enforce at the workload and flow layer, and what evidence can I export?*
- *Which techniques have a defensible mapping to CSW telemetry (flows, processes, inventory) versus those that require endpoint-heavy or identity-centric tooling?*
- *How do I baseline “normal” east-west and north-south behavior so tactic-aligned anomalies (new ports, scanning, beacons, staging) are actionable?*
- *What do I pair with CSW so coverage gaps against ATT&CK do not leave blind spots? (Cisco XDR, EDR, email security, SIEM/SOAR)*

What you'll need. A current workload inventory, ATT&CK Navigator or internal coverage spreadsheet (optional), scope for crown-jewel applications, and integration targets for alerts (SIEM, ticketing, Cisco XDR).

Where to start. Sections 1–2 for executive coverage narrative; 3–7 to deploy and baseline; 8–9 for tactic and technique mapping tables; 10–12 for boundaries, evidence exports, and pitfalls.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof	Enforce; quarterly	Ongoing

Phase	Goal	Key CSW actions	Typical duration
	between audits	export pack; ADM refresh every 90 days	

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: compliance:<framework>, data:<classification>, env:<tier>
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Technique-level forensic alignment (TA0001–TA0011)
- Lateral movement visibility (TA0008) at east-west workload tier
- SOC integration guidance for detection/prevention mapping

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

MITRE ATT&CK is a knowledge base of adversary tactics and techniques, not a compliance checklist. This reference design shows how **Cisco Secure Workload (CSW)** contributes **detection signals, prevention where microsegmentation is enforced**, and **evidence artifacts** aligned to Enterprise tactics. CSW excels at **workload-native visibility**: process context, connection graphs, and policy actions on allowed/denied traffic.

Important distinction: CSW is **not** a full EDR/XDR replacement. It provides strong **network-behavior** and **workload-process** telemetry layered with **segmentation**. For comprehensive ATT&CK coverage, pair CSW with **Cisco XDR** (or another XDR), **managed EDR**, identity threat detection, email security, and a **SIEM** for correlation and retention policies that match your program.

ATT&CK Tactics and CSW Capability Summary

Tactic ID	Tactic	Primary CSW Capabilities
TA0001	Initial Access	Flow anomaly detection; new inbound connections to previously unseen ports on protected workloads; policy blocks on unapproved ingress paths
TA0002	Execution	Forensics / process monitoring: unseen commands , script interpreters spawning unexpected children, DLL side-loading patterns (process + image path context)
TA0003	Persistence	New listening services; package/process change detection; new or modified system services aligned to inventory drift

Tactic ID	Tactic	Primary CSW Capabilities
TA0004	Privilege Escalation	Process privilege context monitoring where sensors provide it; anomalous escalation tooling spawning from low-trust parents
TA0005	Defense Evasion	Baseline drift: new outbound paths; rare processes; unexpected tunnel or proxy behavior visible at flow + process layer
TA0006	Credential Access	Detection of credential-harvesting tool patterns (process name, hash, lineage); suspicious access to security account manager paths (sensor-dependent)
TA0007	Discovery	Network scanning behavior inferred from flow fan-out, failed connections, and sweep patterns on internal segments
TA0008	Lateral Movement	Microsegmentation blocks; east-west flow telemetry ; explicit allowlists for admin protocols (RDP, SSH, SMB, WinRM)
TA0009	Collection	Egress monitoring for staging (bulk internal copy, new internal sinks, unusual cross-zone flows)
TA0010	Exfiltration	Egress flow anomalies ; unusual external destinations; volume/duration outliers
TA0011	Command and Control	C2 beaconing

Tactic ID	Tactic	Primary CSW Capabilities
TA0040	Impact	candidates from periodic flow patterns (interval, jitter-aware review in SIEM), new external long-lived sessions Process anomalies associated with encryption/ransomware-style behavior (mass file-touch patterns visible indirectly via process + egress); containment via policy

2. Pre-Deployment Checklist

Before deploying CSW sensors for ATT&CK-aligned use cases, confirm:

- ☐ CSW cluster (SaaS or on-premises) is provisioned and accessible
- ☐ Outbound connectivity from workloads to the cluster (typically TCP 443)
- ☐ Linux/Windows sensor compatibility verified for **crown-jewel** and **Tier-0** adjacent systems first
- ☐ Cloud connectors configured (AWS, Azure, GCP) where agentless flow visibility is required
- ☐ **SIEM or XDR** destination for alerts identified (normalize tactic tags in event forwarding)
- ☐ Stakeholders aligned: SOC Lead, Detection Engineering, Infrastructure Owner
- ☐ Change window approved: start in **monitoring-only** enforcement on production

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 On-Premises Workloads

Install software sensors:

```
# Linux (RHEL/CentOS)
sudo rpm -ivh tet-sensor-<version>.rpm
```

```
# Linux (Ubuntu/Debian)
sudo dpkg -i tet-sensor-<version>.deb
```

```
# Verify service
systemctl status csw-agent
```

Windows: deploy via your standard package pipeline (MSI); confirm the agent reports **Active** in the CSW console.

3.2 Cloud Workloads

VM-based: same sensor installs as on-premises.

Agentless visibility (connectors):

CSW UI → Platform → External Orchestrators
→ Add AWS / Azure / GCP connector
→ Grant least-privilege IAM/SPN for inventory + flow ingestion (e.g., VPC Flow Logs)

3.3 Initial Posture

- Enforcement: **Monitoring only** until baselines exist.
- Enable **process hash**, **flow**, and **vulnerability/reachability** features supported in your SKU.
- Tags: apply `criticality:crown-jewel`, `mitre:protected`, `env:production` consistently.

Validation:

CSW UI → Manage → Agents
→ Status: Active for all in-scope hosts
→ Confirm flow and process tiles populated for sample workloads

4. Phase 2 — Scope Design (Days 6–10)

4.1 Recommended Scope Hierarchy for ATT&CK Use Cases

Organize scopes to match **lateral movement choke points** and **high-value data stores**.

```
Root: Enterprise-ATTCK
├─ Tier0-Identity-Adjacent      # AD, PKI, MFA brokers (if
instrumented)
├─ Crown-Jewel-Apps            # ERP, data warehouse, pipeline
controllers
├─ Server-Farm-General
├─ Jump-Host-Enclave
├─ DevTest-Isolated
└─ Internet-Facing-Entry        # ingress inspection + strict outbound
```

4.2 Inventory Filters for “First Defenders”

Filter: Internet-Facing-Listeners

- Scope: Internet-Facing-Entry + cloud public subnets
- Listening ports: any (review against change tickets)

Filter: Sensitive-Data-Stores

- Process: mysqld, postgres, oracle, mongo*, sqlservr, etc.
- Tags: data-classification = restricted / secret

4.3 Labeling Strategy

Label	Example	Use
criticality	crown-jewel, standard	Prioritize detections and baselines
attack-surface	internet-facing, internal-only	Ingress anomaly policies
data-class	restricted, public	Exfiltration monitoring scope
owner-team	app-owners, platform	Incident routing

5. Phase 3 — Visibility & Baseline (Days 11–21)

5.1 Application Dependency Mapping (ADM)

ADM establishes **normal** conversations—required to separate benign admin traffic from lateral movement.

CSW UI → Investigate → Application Dependency Mapping

- New Workspace: "ATTACK-Baseline-<YYYY-Qx>"
- Scope: Crown-Jewel-Apps + Tier0-Identity-Adjacent (expand as needed)
- Window: minimum 2–4 weeks (cover patch Tuesday and month-end jobs)
- Enable process context on sensors that support it

5.2 Baseline Review Questions (Tactic-Oriented)

Review focus	ATT&CK relevance
First-time inbound ports on internet-facing tiers	TA0001
Rare outbound destinations from Tier-0 adjacent subnets	TA0011, TA0010
East-west fan-out (many internal targets in short window)	TA0007, TA0008
Long-lived low-and-slow sessions to new external IPs	TA0011
New services or listeners without change correlation	TA0003

5.3 Export Baseline Snapshot

Periodically export ADM graph or policy-import baseline for **drift comparison** during purple-team or assessor walkthroughs.

6. Phase 4 — Policy Design (Days 22–35)

Design policies that **reduce blast radius** (tactics TA0008, TA0010, TA0011) while **logging** novel paths for detection (TA0001, TA0007).

6.1 Illustrative Segmentation Policy Snippets

Default posture for crown-jewel tier (conceptual — adapt to your workspace syntax):

```
# Deny lateral paths not observed in ADM (after simulation)
DENY: Server-Farm-General → Crown-Jewel-Apps (default)
ALLOW: Jump-Host-Enclave → Crown-Jewel-Apps (tcp/22, tcp/3389, tcp/443
as approved)
ALLOW: Crown-Jewel-Apps → Approved-Patch-Mirrors (tcp/443)
```

```
# Contain internet-facing tier: no direct egress except proxies
DENY: Internet-Facing-Entry → Internet (except via Egress-Proxy scope)
```

```
# Log everything unmatched for SOC review
LOG: Any → Any (unmatched)
```

Operational note: translate the above into your CSW **Defend** → **Segmentation** workspace rules; run **Simulation** until change tickets align with observed noise.

6.2 Jump-Host and Break-Glass

- Model **explicit** allowed admin paths (TA0008 overlap with legitimate ops).
- Use a separate **alert-only** workspace for emergency access nets if required; document in reference designs.

6.3 Simulation Before Enforcement

Stage	Mode	Goal
1	Simulation	Tune alerts; validate ADM completeness
2	Selective enforcement	Block highest-risk sprawl (open east-west)
3	Full enforcement (scoped)	Containment for defined tiers

7. Phase 5 — Enforcement & Detection Operations

7.1 Mapping Defense Modes to ATT&CK Outcomes

CSW mode	ATT&CK outcomes
Segmentation enforcement	Blocks lateral movement (TA0008), some C2/exfil paths (TA0011, TA0010) when destinations are disallowed
Segmentation monitor + alert	Detects initial access surprises (TA0001), scanning (TA0007), staging (TA0009)
Process / flow analytics	Supports execution, persistence, credential, and impact stories (TA0002–TA0006, TA0040)

7.2 Alert Forwarding (SIEM / XDR)

```
# Example: document webhook/API integration from CSW to your SIEM
# (Exact CLI varies by release – capture in your Confluence reference
# design)
# curl -X POST "$SIEM_HEC_URL/services/collector/event" \
#   -H "Authorization: Splunk $HEC_TOKEN" \
#   -d '{"event": "<CSW alert JSON>"}'
```

Tag forwarded events with **ATT&CK tactic/technique** IDs your SOC standardizes (e.g., `mitre_attack_tactic: lateral-movement`).

7.3 Purple-Team Feedback Loop

- After each exercise, attach **CSW exports** (flows, process timelines, policy hits) to the technique row in Navigator or your coverage sheet.

7.4 ATT&CK-Aligned Alerts (Examples)

Configure or derive alerts so SOC triage can tag **tactic ID** consistently. Exact rule names depend on your CSW release and entitlements; map these examples to your deployed behaviors.

Alert theme	ATT&CK tactics	Typical CSW signal
First-seen inbound port on internet-facing tier	TA0001	New listener + new external source talking to production scope
Rare process or unseen command line on protected host	TA0002	Process forensics deviation from ADM baseline
New Windows service binary or unexpected systemd unit	TA0003	Service / listener creation with new hash

Alert theme	ATT&CK tactics	Typical CSW signal
Child of high-integrity parent spawning tooling from user-writable path	TA0004	Privilege / lineage anomaly (validate with EDR)
Sudden binary or egress path not in last-90-day ADM	TA0005	Drift: flow + process combined
Known credential-dump tool name or suspicious parent → child	TA0006	Process catalog + lineage
Internal connect fan-out / failed connect storm	TA0007	Aggregated flow metrics (finalize thresholds in SIEM)
East-west admin protocol from non-jump scope	TA0008	RDP/SMB/SSH/WinRM to sensitive tier without allow rule
Large cross-zone fan-in to staging host	TA0009	Volume or novelty of internal flows
First connection to rare external AS or geo for scope	TA0010	Egress novelty + duration
Low-volume periodic HTTPS/DNS to young domain	TA0011	Flow timing features (confirm in SIEM)
Many encrypted file extensions touched + mass SMB	TA0040	Process + lateral burst (correlate with EDR file events)

8. Phase 6 — Audit & Assessment Evidence

Maintain artifacts that demonstrate **what was monitored**, **what was blocked**, and **how detections were tuned** over time.

Evidence	CSW source	Typical consumer
Scope & inventory export	Manage → Inventory / Scopes	Risk team, assessors
ADM baseline vs current	Investigate → ADM	Change / architecture review
Policy workspace export	Defend → Segmentation	Segmentation attestation
Alert history with flow context	Alerts + Flow Search	SOC metrics, breach investigation
Simulation →	Change tickets + policy	Governance

Evidence	CSW source	Typical consumer
enforcement approval	version	

9. Control Mapping: ATT&CK → CSW → Evidence

9.1 Tactic-Level Mapping

ATT&CK tactic	Representative techniques (examples)	CSW capability	Evidence produced
TA0001 Initial Access	T1190, T1133, T1566*	Inbound flow anomaly (new service port, rare source); policy deny logs	Flow exports; policy hit timeline; ADM delta
TA0002 Execution	T1059, T1204, T1047	Process monitoring: unseen CLI, scripting engines with rare parents	Process tree exports; hash lineage
TA0003 Persistence	T1543, T1547, T1574	New services/listeners ; package drift; side-loading indicators	Inventory diff; listener reports
TA0004 Privilege Escalation	T1068, T1055	Privilege context + anomalous child processes	Process + user context export
TA0005 Defense Evasion	T1027, T1562, T1070	Baseline drift; new egress; rare binaries	Drift report; flow compare
TA0006 Credential Access	T1003, T1558, T1110**	Credential-tool process patterns; suspicious SAM/LSASS adjacency (platform-dependent)	Process alerts; flow to DC
TA0007 Discovery	T1046, T1018, T1087**	Scanning behavior (failed connect fan-out); internal sweep patterns	Internal flow aggregation
TA0008 Lateral	T1021, T1550	Microsegmentati	Deny logs;

ATT&CK tactic	Representative techniques (examples)	CSW capability	Evidence produced
Movement		on ; east-west allowlist; denied RDP/SMB/SSH/WinRM	allowed-path attest
TA0009 Collection	T1005, T1119	Egress/internal bulk staging patterns	Cross-scope flow report
TA0010 Exfiltration	T1048, T1020	Egress anomaly ; novel external destinations	External flow timelines
TA0011 Command and Control	T1071, T1095, T1573	Beaconing candidates (best finalized in SIEM); long-lived odd sessions	Flow time series export
TA0040 Impact	T1486, T1490	Process anomaly ; encryption-tool patterns; mass connectivity change	Process + policy containment proof

*Phishing (T1566) is primarily **email/identity** telemetry—CSW supports **post-landing** workload evidence only.

Techniques with heavy **identity or **directory query** detail require **IdP, AD, EDR, and authentication logs**; CSW contributes supporting network and process context.

9.2 Technique-Level Alignment (Selected)

Use this table as a **starter mapping**—extend with your forensic rule catalog and SIEM correlations.

Technique ID	Name	CSW alignment	Notes
T1190	Exploit Public-Facing Application	Strong (flows to new internal victims from ingress tier)	Pair with WAF/IPS for exploit payload detail
T1059.001	PowerShell	Medium–strong	Unseen command lines; parent/child anomalies
T1059.003	Windows Command Shell	Medium–strong	Rare cmd.exe children, encoded

Technique ID	Name	CSW alignment	Notes
			patterns (finalize in SIEM)
T1574.002	DLL Side-Loading	Medium	Image load path + process context where available
T1543.003	Windows Service	Medium	New service binary paths; new listeners
T1003.001	LSASS Memory	Medium (process-centric)	Confirm with EDR/kernel telemetry
T1046	Network Service Scanning	Strong (flow fan-out)	Tune thresholds per subnet
T1021.001	Remote Desktop Protocol	Strong (east-west)	Default deny + allowlisted jump paths
T1021.002	SMB/Windows Admin Shares	Strong	Same as above
T1021.004	SSH	Strong	Pair with SSH certificate/auth logs
T1048	Exfiltration Over Alternative Protocol	Medium–strong	Unusual outbound proto/port combos
T1071.001	Web Protocols	Medium	Beaconing analysis in SIEM
T1486	Data Encrypted for Impact	Medium	Process + mass egress suppression; not full file-level integrity

10. Boundaries — What CSW Does **Not** Cover

- **Full ATT&CK matrix coverage:** Many techniques are **identity, email, human,** or **kernel** events outside workload network/process telemetry.
- **EDR-class containment:** CSW does not replace EDR isolation APIs for all endpoint scenarios; use **Cisco XDR** or EDR for host quarantine where required.
- **Log tamper analysis on endpoints:** AU-centric questions may still require OS-level audit subsystems.

- **Cloud control plane attacks** (e.g., IAM abuse without VM traffic): complement with **CSPM/CWPP** and cloud audit logs.
 - **Attribution and intent**: CSW provides **technical behaviors**; threat intelligence and hunting hypotheses live in SIEM/SOAR workflows.
-

11. Audit Preparation & Evidence Export

11.1 Standard Operating Procedure (Flow-Centric Incident)

1. CSW UI → Alerts → open event → note workload, time, policy action
2. Investigate → Flow Search → pivot source/destination + port + window
3. Investigate → Process Search → capture parent chain and hashes
4. Export: CSV/JSON per your retention standard; attach tactic/technique tags
5. Archive: store with ticket ID; map to purple-team or RCA document

11.2 Retention Guidance

Align CSW retention with **SIEM/ISO/internal policy**. Federal-style programs often target **multi-year** cold storage for select events—implement via **forward-and-store**, not console-only retention.

11.3 Companion Products

Gap area	Recommended companion
Cross-domain correlation, case management	Cisco XDR
Deep endpoint telemetry	EDR (Cisco or third party)
Long-term search & compliance queries	SIEM (Splunk, Microsoft Sentinel, etc.)
Email and web initial access	Secure Email/Web Gateway

12. Common Pitfalls

Pitfall	Mitigation
Declaring “full ATT&CK coverage” from CSW alone	Publish a pairing matrix : which tactics are CSW-primary vs SIEM/EDR-primary.
Baseline window too short (misses month-end jobs)	Run ADM ≥ 30 days; include patch and financial close cycles.
Beaconing detected only in CSW console	Export flow time series to SIEM for periodicity / jitter analytics.
Over-blocking lateral admin paths	Model jump hosts explicitly; simulate before enforcement.

Pitfall	Mitigation
Ignoring agentless-only cloud segments	Combine connectors + sensors so east-west is not partially blind.
Credential-access alerts without EDR confirmation	Treat CSW as corroboration for T1003-class techniques pending kernel telemetry.

Appendix A — Sample Detection Engineering Checklist

- ☐ Every **crown-jewel** scope has a current ADM baseline ≤ 90 days old
- ☐ **Internet-facing** tier has ingress anomaly alerts with ticket routing
- ☐ **East-west deny** rules have documented business exceptions
- ☐ **SIEM** parses CSW alert JSON; fields include workload ID, 5-tuple, process
- ☐ Quarterly review maps closed incidents to **ATT&CK technique** IDs

Appendix B — Related Frameworks

- [NIST SP 800-53 Rev 5](#) — control families that overlap SI-4, AU, IR.
- [NIST SP 800-207](#) — ZTA segmentation rationale.
- [FedRAMP](#) — federal continuous monitoring overlays.
- [UK NCSC CAF v3.2](#) — technique coverage is the reuse path for CAF C2.

*Document prepared for Cisco accounts mapping workload telemetry to MITRE ATT&CK.
Replace organization-specific names and parameters before customer delivery.*